

פרויקט סיום – טכנולוגיות אינטרנט ופיתוח פול סטאק

DerbyUp – ניחוש כדורגל לארגונים | מגישים - ניר דהן , ליאב צרפתי | מרצה – אוהד אסולין | הגשה – אוגוסט 2026

מסמך אפיון בדיקות

אסטרטגיית הבדיקות

חלקי האתר שייבדקו

נבדק בקפדנות	נבדק בסיסית
חישוב הניקוד מהיחס, כולל בונוס התוצאה המדויקת	קומפוננטות UI מרכזיות
עיבוד וחישוב דירוג	טפסים
התצוגה החיה	ניווט
הרשאות ובידוד נתונים	
שכבות ההגנה של היועץ	
ולידציות קלט	
התהליך העסקי מקצה לקצה	

כלים

כלי	שכבה
Vitest	יחידה + אינטגרציה
Library Testing React	קומפוננטות
Playwright	E2E בדפדפן אמיתי
בדיקות ידניות מתועדות	מה שלא כדאי לבדוק בצורה אוטומטית

בדיקות לפיצ'רים המרכזיים

חישוב ניקוד - pointsForCorrectPrediction

#	תרחיש	קלט (יחס, בונוס)	צפוי
1	ניחוש נכון, בלי בונוס	0%, 7.15	7.15
2	יחס נמוך	0%, 1.20	1.20
3	ניחוש תוצאה מדויקת	300%, 2.1	6.3
4	בחירת עורך – בונוס 100%	100%, 2.00	4.00
5	עיגול לשתי ספרות	0%, 3.333	3.33
6	עיגול עם בונוס	33%, 2.15	2.86

קביעת תשובה נכונה - resolveOutcome

#	סוג	תוצאה	צפוי
1	match_result	1-2	home
2	match_result	3-0	away
3	match_result	1-1	draw
4	over_under_2_5	1-2 (3=)	over
5	over_under_2_5	1-1 (2=)	under
6	over_under_2_5	0-0	under
7	btts	1-2	yes
8	btts	0-3	no
9	btts	0-0	no

עיבוד ניחוש - settlePrediction

#	תרחיש	צפוי
1	ניחוש נכון ביחס 7.15	$7.15 = \text{pointsEarned ; correct}$
2	ניחוש שגוי	$0 = \text{pointsEarned ; incorrect}$
3	ניחוש נכון עם בונוס 50%	$\text{pointsEarned} = \text{היחס} \times 1.5$
4	היחס המוקפא הוא הקובע	שינוי היחס בשאלה אינו משנה ניחוש קיים
5	משחק בוטל	$0 = \text{pointsEarned ; void}$

דירוג - rankRows

#	תרחיש	צפוי
1	מיון לפי נקודות יורד	הגבוה ראשון
2	שובר שוויון : מספר ניחושים נכונים	בעל יותר פגיעות מקדים
3	שוויון מלא	אותו מקום לשניהם
4	דירוג תחרותי	90/100/100 → מקומות 1, 1, 3
5	רשימה ריקה	מערך ריק, בלי קריסה
6	שורה עם 0 נקודות	מופיעה בטבלה

הישגים - checkAchievements

#	תרחיש	צפוי
1	ניחוש ראשון	first_prediction מוענק
2	9 ניחושים	ten_predictions לא מוענק
3	10 ניחושים	ten_predictions מוענק
4	הישג שכבר הוענק	לא מוענק פעמיים
5	רצף 3 נכונים	streak_three מוענק
6	רצף נשבר	streak_three לא מוענק
7	ניחוש נכון ביחס 5.0	underdog מוענק
8	ניחוש נכון ביחס 4.99	underdog לא מוענק

תוצאה מדויקת - exact-score

#	תרחיש	צפוי
1	מנצחת נכונה + תוצאה מדויקת	פי 3 מהיחס
2	מנצחת נכונה + תוצאה שגויה	היחס המלא, בלי עונש
3	מנצחת שגויה + תוצאה "נכונה"	0 - הבונוס אינו מציל ניחוש שטעה
4	בלי תוצאה מדויקת	היחס המלא
5	בונוס בחירת העורך + תוצאה מדויקת	שניהם מוכפלים : 2.10 הופך ל-9.45
6	סדר העיגול	מוכפל על הבסיס המעוגל - מה שהוצג למשתמש
15-7	פורמטים לא תקינים	2:1 · 1-12 · -2 · a-b · ריק · null - כולם נדחים
25-16	התאמה לבחירה	"ארסנל" עם 1-2 · תיקו עם 2-1 · ועוד

אתגר יומי - checkAnswer / normalizeName

#	תרחיש	צפוי
1	התאמה מדויקת	נכון
2	הבדל רישיות	נכון
3	רווחים מיותרים	נכון
4	ניקוד - "Özil" מול "Ozil"	נכון
5	שם שגוי	לא נכון
6	מחרוזת ריקה	לא נכון
7	ניקוד לפי ניסיון	1→3, 3→2, 5→1

התצוגה החיה - live-projection

#	תרחיש	צפוי
1	כל סוגי השאלות מול תוצאה נוכחית	מוביל / לא מוביל, והנקודות בהתאם
2	0-0 בתחילת משחק	0 לכל מי שניחש צד
3	תוצאה מדויקת שתואמת את הרגע	פי 3
4	שער שוויון אחרי שהבונוס כבר הוצג	6.00 יורד ל-0 - המספר יכול לרדת, וזו התנהגות נכונה
5	מנצחת נכונה, תוצאה מדויקת שגויה	היחס המלא
6	בונוס בחירת העורך	מוכפל, כמו בעיבוד
7	ניחוש עם יחס משוער	מתומחר לפי מחיר השאלה, לא לפי הפלייסהולדר
8	ניחוש רגיל שהיחס שלו זז	לפי היחס המוקפא
9	סיכום פר-חבר	סכום הניחושים המובילים, מעוגל לשתי ספרות
10	חבר בלי ניחוש מוביל	נעדר מה-Map - לא מופיע כאפס

בדיקות לקלטים לא תקינים

סכימות Zod

#	סכימה	קלט פסול	צפוי
1	signUpSchema	אימייל בלי @	נדחה
2	signUpSchema	סיסמה 7 תווים	נדחה
3	makePredictionSchema	questionId לא UUID	נדחה
4	makePredictionSchema	outcome ריק	נדחה
5	makePredictionSchema	outcome ארוך מ-20	נדחה
6	makePredictionSchema	exactScore בפורמט 2:1	נדחה
7	createLeagueSchema	שם באורך 2	נדחה
8	createLeagueSchema	שם באורך 61	נדחה
9	createLeagueSchema	בלי competitionId	נדחה (חובה)
10	createLeagueSchema	competitionId שלילי	נדחה
11	joinLeagueSchema	קוד באורך 7	נדחה
12	joinLeagueSchema	קוד עם תווים מיוחדים	נדחה
13	prizesSchema	0 = place	נדחה
14	prizesSchema	21 פרסים	נדחה (מקסימום 20)
15	askAdvisorSchema	שאלה מעל 300 תווים	נדחה
16	adminSettleSchema	תוצאה שלילית או מעל 99	נדחה

קלט זדוני

#	תרחיש	צפוי
1	<script> בשם התצוגה	נשמר כטקסט ; מוצג ולא מורץ
2	<script> בטקסט פרס	נשמר כטקסט ; מוצג ולא מורץ
3	' OR 1=1 -- בקוד הזמנה	נדחה בולידציה ; ללא SQL injection
4	שדות עודפים ב-payload	מתעלמים מהם
5	null בשדה חובה	נדחה
6	מחרוזת ענקית (מעל 1MB)	נדחה על חריגת אורך
7	outcome שאינו מבין האפשרויות	נדחה בשרת
8	Prompt injection ליועץ	נחסמת בשכבה 1, לפני כל קריאה בתשלום

בדיקות לתהליכים עסקיים מרכזיים

כללי ניחוש - validatePrediction

#	תרחיש	צפוי
1	כל התנאים תקינים	מאושר
2	המשחק כבר התחיל	GAME_STARTED
3	שנייה אחרי שריקת פתיחה	GAME_STARTED
4	שנייה לפני שריקת פתיחה	מאושר
5	ניחוש כפול לאותה שאלה	ALREADY_PREDICTED
6	משחק בסטטוס finished	GAME_NOT_OPEN
7	משחק בסטטוס cancelled	GAME_NOT_OPEN
8	משחק בסטטוס live	GAME_NOT_OPEN
9	לא חבר בליגה של התחרות	NO_LEAGUE_FOR_COMPETITION
10	חבר בליגה של תחרות אחרת	NO_LEAGUE_FOR_COMPETITION

כללי ביטול - validateCancellation

#	תרחיש	צפוי
1	ביטול 60 דקות לפני הפתיחה	מאושר
2	ביטול 11 דקות לפני	מאושר
3	ביטול בדיוק 10 דקות לפני	CANCEL_WINDOW_CLOSED
4	ביטול 9 דקות לפני	CANCEL_WINDOW_CLOSED
5	ביטול אחרי שהמשחק התחיל	CANCEL_WINDOW_CLOSED
6	ביטול ניחוש שכבר יושב	ALREADY_SETTLED
7	ביטול ניחוש של משתמש אחר	NOT_OWNER
8	ביטול ניחוש שכבר בוטל	ALREADY_SETTLED

מחזור חיים מלא של ניחוש

#	שלב	אימות
1	ניחוש משחק	רשומת predictions בסטטוס pending
2	ניחוש משחק	היחס הוקפא בערכו בזמן הניחוש
3	ניחוש משחק	bonus_pct נלקח ממשחק השבוע של הליגה
4	ניחוש משחק	points_earned הוא null
5	עיבוד – ניחוש נכון	סטטוס points_earned ; correct = היחס המוקפא
6	עיבוד – ניחוש נכון	profiles.total_points עודכן
7	עיבוד – ניחוש נכון	profiles.total_correct עלה ב-1
8	עיבוד – ניחוש נכון	נוצרה התראה למשתמש
9	עיבוד – ניחוש שגוי	סטטוס points_earned ; incorrect = 0
10	עיבוד – ניחוש שגוי	total_points לא השתנה

ביטול ניחוש

#	תרחיש	אימות
1	ביטול ניחוש תקין	סטטוס cancelled_at ; cancelled מולא
2	ביטול ניחוש תקין	ניתן לנחש מחדש באותה שאלה
3	ניחוש מבוטל אינו מיושב	ה-cron מתעלם ממנו
4	ניחוש מבוטל אינו נספר בדירוג	הדירוג ללא שינוי
5	ביטול כפול במקביל	פעולה אחת בלבד ; בלי שגיאה כפולה
6	ניסיון UPDATE ישיר על predictions	נדחה ב-RLS
7	ניסיון DELETE ישיר על predictions	נדחה ב-RLS

חישוב דירוג הליגה

#	תרחיש	צפוי
1	חבר עם 3 ניחושי מנצח נכונים	סכום שלושת היחסים
2	חבר עם ניחושים נכונים ושגויים	רק הנכונים נספרים
3	ניחוש over_under_2_5 נכון	לא נספר בליגה
4	ניחוש btt נכון	לא נספר בליגה
5	נקודות מהאתגר היומי	לא נספרות בליגה
6	ניחוש מנצח בתחרות אחרת	לא נספר בליגה הזו
7	ניחוש מנצח לפני ההצטרפות	לא נספר
8	ניחוש מנצח אחרי ההצטרפות בתחרות הנכונה	נספר
9	אותו משתמש בשתי ליגות של אותה תחרות	אותו ניקוד בשתייהן
10	אותו משתמש בשתי ליגות של תחרויות שונות	ניקוד שונה בכל אחת
11	ניחוש מבוטל	לא נספר
12	ניחוש void (משחק בוטל)	לא נספר
13	חבר שניחש רק Over/Under ו-BTTS	0 נקודות בליגה

לידרבורד האתר

#	תרחיש	צפוי
1	ניחוש match_result נכון	נספר
2	ניחוש over_under_2_5 נכון	נספר
3	ניחוש btt נכון	נספר
4	נקודות מהאתגר היומי	נספרות
5	ניחוש בתחרות כלשהי	נספר, בלי קשר לליגה
6	משתמש בלי ליגה כלל	מופיע בלוח
7	ניחוש שגוי	לא מוסיף
8	ניחוש מבוטל	לא נספר
9	הסכום שווה ל- profiles.total_points	תואם
10	מיון	לפי total_points יורד
11	limit מעל 100	נחתך ל-100

הפרדה בין שני הלוחות

#	תרחיש	צפוי
1	משתמש מנחש נכון מנצח (2.10) + (1.75) BTTS באותו משחק בטורניר הליגה	ליגה: 2.10 · כללי: 3.85
2	משתמש פותר אתגר יומי (5 נק') בלבד	ליגה: 0 · כללי: 5
3	משתמש מנחש מנצח בטורניר אחר	ליגה: 0 · כללי: היחס
4	שני משתמשים - א' חזק בליגה, ב' חזק בכללי	הסדר שונה בין הלוחות

יצירה והצטרפות לליגה

#	תרחיש	צפוי
1	יצירת ליגה	נוצרה; קוד באורך 8; היוצר הוא creator_id
2	יצירת ליגה	היוצר נוסף אוטומטית כחבר
3	יצירת ליגה	competition_id נשמר
4	קוד ייחודי	שתי ליגות → שני קודים שונים
5	הצטרפות בקוד תקין	נוצרה חברות; joined_at נרשם
6	הצטרפות בקוד שגוי	INVALID_CODE
7	הצטרפות כפולה	נדחה; אין כפילות
8	קוד של ליגה בארכיון	נדחה
9	אדמין מעדכן פרסים	נשמרו כ-JSONB

#	תרחיש	צפוי
1	תשובה נכונה בניסיון 1	5 נקודות
2	נכונה בניסיון 2	3 נקודות
3	נכונה בניסיון 3	1 נקודה
4	ניסיון 4	נדחה
5	תשובה נכונה אחרי שכבר פתר	נדחה; אין זיכוי כפול
6	הנקודות אינן נספרות בדירוג הליגה	דירוג הליגה ללא שינוי
7	הנקודות נספרות בלידרבורד הכללי	total_points עלה

שכבת הלייב

הסנכרון - מה מותר לו לגעת בו :

#	תרחיש	צפוי
1	משחק חי קיים	תוצאה, דקה ו-live_updated_at נכתבו
2	ניחושים ונקודות	status=pending, points_earned=null - בלי שינוי
3	הספק מחזיר משחק שאין לנו	לא נוצרת שורה
4	משחק שכבר עובד, והספק עדיין מדווח אותו כחי	התוצאה המעובדת נשמרת ולא נדרסת
5	הספק מחזיר 503	השגיאה מדווחת, שום שורה לא זזה
6	false=LIVE_SCORES_ENABLED	הפונקציה עוצרת לפני הקריאה לספק
7	חבר עם ניחוש מוביל במשחק חי	ה-delta שווה ליחס
8	תוצאה מדויקת שתואמת את הרגע	פי 3 גם בשכבה החיה
9	משתמש שאינו חבר בליגה	NOT_A_MEMBER
10	ניחוש שנעשה לפני ההצטרפות	לא נספר - כמו ב-league_standings
11	ניחוש Over/Under	לא נספר בטבלת הליגה - כמו ב-league_standings
12	משחק שהסתיים וטרם עובד	עדיין נספר - אחרת הטבלה מתאפסת ל-10 דקות
13	אחרי שהעיבוד רץ	ה-delta נעלם, ו-league_standings מציגה בדיוק את אותו מספר
14	העיבוד סוגר משחק	minute מתנקה - אין שארית של "55" על משחק שנגמר

בדיקות הרשאות

בידוד נתונים

#	תרחיש	צפוי
1	משתמש א' קורא ניחושים של ב'	0 שורות
2	א' מנסה UPDATE על ניחוש של ב'	נדחה
3	א' מנסה DELETE על ניחוש של ב'	נדחה
4	א' מנסה UPDATE על הניחוש שלו	נדחה (רק דרך הפונקציה)
5	א' קורא ל-cancel_prediction על ניחוש של ב'	נדחה (NOT_OWNER)
6	א' קורא התראות של ב'	0 שורות
7	א' קורא ניסיונות אתגר של ב'	0 שורות
8	א' קורא ליגה שאינו חבר בה	0 שורות
9	א' קורא חברי ליגה שאינו חבר בה	0 שורות
10	א' ובי' באותה ליגה - א' רואה את הדירוג	רואה, כולל את ב'
11	משתמש לא מחובר קורא profiles	0 שורות
12	א' מנסה לשנות total_points ישירות	נדחה
13	א' מנסה לשנות points_earned בניחוש שלו	נדחה
14	א' קורא ישירות select * from profiles	רק עצמו + חברי ליגותיו
15	א' קורא ל-get_global_leaderboard	מקבל את כולם - בלי id ובלי username
16	אורח קורא ל-get_global_leaderboard	נדחה (רק authenticated)

הרשאות אדמין ליגה

#	תרחיש	צפוי
1	האדמין מסמן משחק שבוע	מצליח
2	חבר רגיל מסמן משחק שבוע	נדחה
3	חבר רגיל מעדכן פרסים	נדחה
4	חבר רגיל מיישב ידנית	נדחה
5	אדמין של ליגה א' מנהל ליגה ב'	נדחה
6	משתמש שאינו חבר ניגש ל- <code>/leagues/[id]/admin</code>	הפניה/403

הרשאות מנהל אתר

#	תרחיש	צפוי
1	משתמש רגיל קורא ל- <code>admin_overview</code>	NOT_SITE_ADMIN
2	מנהל אתר קורא לאותה פונקציה	מקבל מונים
3	משתמש רגיל קורא ל- <code>admin_list_users</code>	נדחה
4	מנהל אתר מחפש לפי אימייל	שורה אחת, כולל הכתובת
5	משתמש רגיל קורא לרשימות המשחקים והליגות	נדחה
6	משתמש רגיל קורא לניחושים של אחר	נדחה
7	משתמש מעדכן <code>is_site_admin</code> על השורה שלו	נדחה בטריגר, נשאר false
8	משתמש רגיל ממנה את עצמו דרך הפונקציה	נדחה
9	מנהל אתר משנה את ההרשאות של עצמו	CANNOT_CHANGE_SELF
10	מנהל אתר ממנה ומסיר משתמש אחר	מצליח בשני הכיוונים
10א	משתמש רגיל קורא את רשימת המנהלים	NOT_SITE_ADMIN
10ב	רשימת המנהלים אחרי מינוי והסרה	מתעדכנת בשני הכיוונים, כולל האימייל
11	משתמש רגיל מעבד משחק	נדחה, המשחק לא נגע
12	מנהל אתר מעבד משחק שהתחיל	נרשם, <code>settled_at</code> נשאר ריק
13	עיבוד משחק שטרם התחיל	GAME_NOT_STARTED
14	מחיקת מנהל אחר	CANNOT_DELETE_ADMIN עד להסרת ההרשאה
15	מחיקת משתמש	החשבון והניחושים נמחקים
16	מנהל אתר מוחק את עצמו	CANNOT_DELETE_SELF

שכבות ההגנה של היועץ

שכבה 1 - כללים דטרמיניסטיים. נבדקת ממצה כי היא ניתנת לכך: אין בה רשת ואין מודל.

קבוצה	דוגמאות	צפוי
קלט תקין	שאלה רגילה · רווחים מיותרים	עובר, מנורמל
קלט פגום	ריק · תו אחד · תווי בקרה	נדחה
אורך	300 תווים · 301 · ריפוד של 300 רווחים	גבול, נדחה, עובר
קישורים	<code>https://</code> · <code>www.</code> · אותיות גדולות	נדחה
Prompt injection	10 תבניות בעברית ובאנגלית	נדחה

שכבה 2 - הפלט מול המציאות:

תרחיש	צפוי
ניתוח תקין	עובר, ומקבל תווי ויחס מהשורה שלנו
תשובה קטומה	נדחה
סוג שאלה שאינו קיים במשחק	InsightRejected
outcome_key שאינו קיים במשחק	InsightRejected

הגנת מסלולים

#	תרחיש	צפוי
1	אורח ניגש ל-/dashboard	הפניה ל-/login
2	אורח ניגש ל-/games	הפניה ל-/login
3	אורח ניגש ל-/	מוצג
4	מחובר ניגש ל-/login	הפניה ל-/dashboard
5	קריאה ל-cron בלי CRON_SECRET	401
6	קריאה ל-cron עם secret שגוי	401
7	מחובר שאינו מנהל אתר ניגש ל-/admin	הפניה ל-/dashboard
8	מנהל אתר ניגש ל-/admin	הדאשבורד נטען, והניווט למשתמשים עובד

בדיקות למסד הנתונים

#	תרחיש	צפוי
1	odds קטן מ-1	CHECK דוחה
2	bonus_pct = 150	CHECK דוחה
3	attempt_number = 4	CHECK דוחה
4	exact_score בפורמט לא חוקי	CHECK דוחה
5	username כפול	UNIQUE דוחה
6	invite_code כפול	UNIQUE דוחה
7	שני ניחשים לאותה שאלה מאותו משתמש	UNIQUE דוחה
8	ניחוש לשאלה שלא קיימת	FK דוחה
9	ליגה בלי competition_id	NULL NOT דוחה
10	סטטוס לא חוקי ('foo')	CHECK דוחה
11	מחיקת משתמש	הניחשים נמחקים ב-cascade
12	מחיקת ליגה	החברויות נמחקות ב-cascade
13	מחיקת משחק	השאלות נמחקות ב-cascade
14	הרשמה	הטריגר יצר פרופיל
15	הרשמה	total_points = 0 (בלי מענק)
16	שתי חברויות זהות	UNIQUE דוחה
17	שני אתגרים לאותו תאריך	UNIQUE דוחה
18	שני ניתוחי יועץ לאותו (משחק, hash)	UNIQUE - נשמר הראשון

בדיקות למקרי קצה

קצוות בזמן

#	תרחיש	צפוי
1	ניחוש בדיוק בשנייה של שריקת הפתיחה	נדחה
2	ניחוש שנייה לפני	מאושר
3	משחק שנדחה אחרי שהונחו ניחשים	הכל ל-void, 0 נקודות
4	תוצאה מגיעה פעמיים מה-API	עיבוד פעם אחת בלבד
5	משחק בלי תוצאה למרות finished	לא מיושב; מתועד
6	הצטרפות לליגה באותה שנייה של ניחוש	הכלל >= עקבי

מקרי קצה

#	תרחיש	צפוי
1	ליגה בלי חברים	דירוג ריק, בלי קריסה
2	חבר בלי ניחושים	0 נקודות, מופיע בטבלה
3	משחק בלי יחסים מה-API	יחסי ברירת מחדל
4	יחס גבוה מאוד (50.0)	מחושב תקין
5	שם קבוצה ארוך מאוד	נחתך בתצוגה, לא שובר פריסה
6	200 חברים בליגה	pagination עובד; הדירוג נכון
7	אתגר יומי לא פורסם	הודעה מתאימה, בלי קריסה
8	ליגה בתחרות בלי משחקים קרובים	מצב ריק מדבר

מקביליות

#	תרחיש	צפוי
1	שני ניחושים במקביל לאותה שאלה	אחד מצליח, השני נדחה ב-UNIQUE
2	ה-cron רץ פעמיים במקביל	ישוב יחיד
3	הצטרפות כפולה במקביל	חברות אחת
4	ביטול וניחוש חדש במקביל	מצב עקבי

כשל בספק החיצוני

#	תרחיש	צפוי
1	ה-API מחזיר 500	ה-cron נכשל בשקט; נתונים קיימים נשמרים
2	ה-API ב-timeout	לוג; אין קריסה
3	חריגת מכסה (429)	לוג; ניסיון חוזר בהרצה הבאה
4	תשובה במבנה לא צפוי	נדחית בולידציה; אין כתיבה שגויה
5	יחסים חסרים לשוק מסוים	ברירת מחדל; השאלה עדיין נוצרת
6	Gemini לא זמין או מחזיר תשובה פסולה	היועץ מציג "לא זמין כרגע"; שום דבר לא נכתב

בדיקות UI בסיסיות

קומפוננטות (React Testing Library)

#	קומפוננטה	בדיקה
1	GameRow	מציגה שמות קבוצות ומועד
2	GameRow	בחירת העורך מסומנת עם הבונוס
3	QuestionCard	כל אפשרות מציגה את הנקודות שיתקבלו
4	QuestionCard	אחרי ניחוש - מצב "ניחשת" + כפתור ביטול
5	QuestionCard	משחק שהתחיל - האפשרויות נעולות
6	QuestionCard	תוך שליחה - האפשרויות ננעלות
7	QuestionCard	לחיצה על מנצחת פותחת את בורר התוצאה ואינה שולחת
8	QuestionCard	"בלי תוצאה" שולח את הניחוש בלי הבונוס
9	LeaderboardTable	מציגה שורות לפי סדר, עם דירוג תחרותי
10	LeaderboardTable	שורת המשתמש הנוכחי מודגשת
11	LeaderboardTable	משמשת את שני הלוחות עם אותם props
12	PrizeList	מציגה פרסים לפי מקום
13	PrizeList	ליגה בלי פרסים - לא מוצג כלום
14	PuzzleBoard	אוטוקומפליט מציג לפי טקסט חלקי
15	EmptyState	מוצג כשאין נתונים
16	Pagination	מנוטרל בעמוד הראשון/האחרון

#	קומפוננטה	בדיקה
17	ThemeColorPicker	מציגה את ערכות הצבע, ברירת המחדל מסומנת
18	ThemeColorPicker	בחירה צובעת את הדף ונשמרת ב-localStorage
19	GameRow	משחק חי - תוצאה ודקה במקום שעת הפתיחה
20	QuestionCard	במשחק חי מוצג כמה הניחוש צובר כרגע, ושוה לא סופי
21	LeaderboardTable	התוספת החיה מוצגת בנפרד מהסכום
22	LiveScore	תוצאה, דקה וטקסט נגיש "משחק חי" לקורא מסך
23	FixturePreview	בלי משחקים במסד - משחק לדוגמה, מסומן ככזה
24	FixturePreview	יחס זמני נאמר כהערכה ולא כמחיר סופי
25	ScoringModel	הבנוס על תוצאה מדויקת נגזר מהקבוע, לא מהעותק

קומפוננטות היועץ

ה-Actions ממוקדות ; Gemini לעולם אינו נקרא מבדיקה.

#	תרחיש	צפוי
1	כרטיס הדעה	מציג משפט, בחירה, יחס ונימוקים
2	אין אחוזים, תוחלת או "ביטחון"	הטקסט אינו מכיל אותם
3	הסתייגות	"לא תחזית ודאית" מופיע
4	טעינה מוצלחת	ניתוח + מונה "נותן N שאלות"
5	כשל בניתוח	שגיאה, ובלי שדה שאלה
6	מכסה אפס	הקלט מושבת, הטקסט "נגמרו השאלות להיום"
7	שאלה ותשובה	התשובה מוצגת, המונה יורד
8	שאלה מחוץ לתחום	הסירוב מוצג כסירוב
9	הקריאה נכשלה	בועת השאלה מוסרת מהמסך
10	שיחה קיימת	נטענת בפתיחה
11	כרטיס הבחירה היומית	מקשר ל-games/{id}/

היועץ בדפדפן אמיתי (E2E)

#	תרחיש	צפוי
1	משתמש מחובר פותח משחק ולוחץ "שאל את היועץ"	הפאנל נפתח, הדעה מוצגת, והמכסה לא נגרעה (cache hit)
2	משחק שכבר התחיל	הכפתור אינו קיים

בדיקות ידניות מתועדות

#	בדיקה	למה ידנית
1	תצוגה במובייל אמיתי (iOS/Android)	התנהגות דפדפן אמיתי
2	סנכרון מול API-Football אמיתי	תלוי בנתונים חיים
3	סבירות היחסים שמגיעים מה-API	היחסים הם הניקוד - שיפוט אנושי נדרש
4	קריאות הטקסטים בעברית	שיפוט אנושי
5	ניגודיות במצב כהה	שיפוט חזותי
6	הרצת ה-cron ב-Vercel	תלוי בסביבת הפרודקשן
7	תוצאה חיה מול משחק אמיתי	תלוי במשחק שמתנהל בפועל ; נבדק ב-22.8 מול 7 משחקים חיים
8	קריאות הנקודה הפועמת ותוספת ה-+ במצב כהה	שיפוט חזותי

```
npm test # 331 unit + component tests, < 1s
npm run test:integration # 196 tests against live Supabase
npm run test:e2e # 27 Playwright browser tests
npm run test:all # all three Vitest suites
npm run test:coverage # coverage report -> coverage/index.html
```

קבצי הבדיקות בתיקייה tests בפרויקט. ניתן להריצן לפי הפקודות המצורפות. הקובץ הקורץ על ידינו 554/554 בדיקות עברו – 100%.

מסמך סקייל בסיסי

הקדמה

בעולם של היום, באותו האופן שהעלאת מוצר לאוויר מתבצעת בזמן שיא, כך גם מוצרים יכולים להגיע ל-scale גבוה תוך רגע. בעקבות כך נדרש בעינינו מכל מוצר להיערך לאותו הרגע – בו המוצר יכול "להתפוצץ" ולצבור כמות משתמשים גבוהה בזמן קצר. ההיערכות תבוא לידי ביטוי בזיהוי הרגעים בהם צפוי עומס על המערכת, והכנת צעדים "נצורים" למתן מענה לאותן הבעיות.

במוצר הקיים איתו יצאנו לשוק, ביום בו נפתחה ליגת העובדים לצ'ק פוינט, נוספו לנו כמעט 500 משתמשים – שינוי גדול ומהיר בסקייל. הגדילה עבדה בצורה חלקה, כתוצאה מהכנה מיטבית שבאה לידי ביטוי בהגדלת הקיבולות של השירותים החיצוניים, בניית caching, פריסת השרתים במספר נקודות בעולם ועוד.

במסמך זה נפרט את הצעדים שנבצע במידה והסקייל שלנו יגדל.

מה יקרה עם עשרות עד מאות משתמשים פעילים

פרופיל העומס הצפוי

מאפיין	ערך צפוי
ארגון ממוצע	100–500 עובדים
שיעור השתתפות	20–40%
משתמשים פעילים בליגה	30–200
תבנית העומס	פרצי שיא, לא זרימה אחידה

הפרץ - התובנה המרכזית

השימוש אינו ממוזר. הוא מתרכז בשני חלונות:

חלון	מה קורה	עומס
כשעה לפני מחזור	כולם מנחשים	שיא כתיבה
מיד אחרי עיבוד (בסיום משחק)	כולם בודקים את הטבלה	שיא קריאה
שאר הזמן	פעילות מינימלית	נמוך עד אפסי

המשמעות: ליגה של 200 עובדים יכולה לייצר 200 כתיבות ב-10 דקות ואז "שקט" יחסי. התכנון מתייחס לשיא, לא לממוצע.

שאלות למסד הנתונים שעלולות להיות כבדות

שאלות "כבדות" בפוטנציאל

#	שאלתה	למה כבדה	מענה בתכנון
1	דירוג הליגה	אגרגציה מחושבת לכל חבר	אינדקס חלקי + pagination + מסלול ל-view materialized
2	לידרבורד האתר	מיון על כל המשתמשים	זול - עמודת cache + אינדקס ממוין
3	היסטוריית ניחושים	גדלה ללא הגבלה	אינדקס + pagination
4	משחקים קרובים	סינון על תחרות וטווח זמן	אינדקס משולב
5	עיבוד ניחוש	עדכון המוני	עיבוד באצווה
6	התראות שלא נקראו	סינון על עמודה דלילה	אינדקס חלקי
7	הטבלה החיה	ניחושים תלויים של כל החברים	חסומה מלמעלה - רק משחקים חיים, רק pending, רק שוק המנצחת

טבלת דירוג - השאילתה היקרה ביותר במערכת

זו הנקודה הכבדה ביותר, כתוצאה ישירה מהחלטה ארכיטקטונית: לליגה אין עמודת ניקוד מאוחסנת, והדירוג מחושב בזמן קריאה מסכום הנקודות של כל חבר על משחקי התחרות של הליגה, מרגע הצטרפותו.

```
select lm.user_id, p.display_name,
       coalesce(pred.pts,0) + coalesce(puz.pts,0) as league_points
from league_members lm
join profiles p on p.id = lm.user_id
left join lateral (
  select sum(pr.points_earned) as pts
  from predictions pr
  join questions q on q.id = pr.question_id
  join games g on g.id = q.game_id
  where pr.user_id = lm.user_id and pr.status = 'correct'
  and g.competition_id = $1 and pr.predicted_at >= lm.joined_at
) pred on true
left join lateral (...) puz on true
where lm.league_id = $2
order by league_points desc;
```

העלות: subquery לכל משתתף - $O(\text{members} \times \text{predictions_per_member})$. לליגה של 200 משתתפים עם 100 ניחושים לכל אחד - כ-20,000 שורות. מהתייעצות עם סוכני הקידוד בהם השתמשנו, ראינו שעלות זו זניחה.

מה מוריד את העלות:

מנגנון	תרומה
idx_pred_user_status - אינדקס חלקי על status='correct'	סורק רק ניחושים נכונים - כשליש מהנפח
idx_games_comp_kickoff	סינון התחרות בלי סריקת games
games מוגבלת לעונה הנוכחית בלבד	~2,000 שורות, לא היסטוריה מצטברת

לידברוד האתר - "זול"

בניגוד לדירוג הליגה, הלוח הכללי אינו מחושב:

```
select display_name, avatar_url, total_points
from profiles order by total_points desc limit 20 offset $1;
```

profiles.total_points הוא cache שמתעדכן בעיבוד הניחוש, ועם **idx_profiles_leaderboard** (אינדקס ממוין) ה-DB קורא 20 שורות ישירות מהאינדקס - בלי מיון ובלי אגרגציה.

אינדקסים

קריטיים - בלעדיהם כל שאילתה היא סריקה מלאה.

אינדקס	סוג	השאילתה	הרווח
idx_pred_user_status	חלקי (status='correct')	טבלת דירוג	סורק רק ניחושים נכונים
idx_pred_user_time	B-tree משולב	היסטוריה	סריקה ממוקדת
idx_pred_question_status	B-tree משולב	עיבוד	איתור מהיר של הממתינים
idx_games_comp_kickoff	B-tree משולב	משחקי התחרות	סינון יעיל בדירוג
idx_games_status_kickoff	B-tree משולב	משחקים קרובים + שומר הסנכרון החי	סינון יעיל; משרת גם את ה-cron
idx_notif_user_unread	חלקי	התראות	אינדקס קטן - רק לא-נקראות
idx_players_trgm	trigram GIN	autocomplete	חיפוש text% יעיל
idx_profiles_site_admin	חלקי (is_site_admin)	רשימת מנהלי האתר	קומץ שורות במקום סריקת כל הפרופילים
idx_advisor_insights_game	B-tree משולב	ניתוח למשחק לפי hash	פגיעת cache בקריאה אחת
idx_advisor_pick_date	B-tree משולב	הבחירות של היום	קריאת הדאשבורד
idx_advisor_messages_thread	B-tree משולב	שחזור שיחה	ישן-לחדש בלי מיון

הימנעות מטעינת מידע מיותר

טעינה לפי הצורך

מה נטען	איך נטען
היסטוריית ניחושים	20 לעמוד
דירוג ליגה	20 לעמוד
לידרבורד האתר	20 לעמוד, מוגבל ל-100 בשרת
משחקים	לפי יום בלוח השנה, שאילתה אחת לכל הניחושים בעמוד
שאלות	רק של המשחק הנוכחי
התראות	20 אחרונות
נתוני שחקנים ליועץ	נשלפים רק כשהשאלה באמת דורשת אותם

cache

שכבה	מנגנון
נתוני משחקים	נשמרים ב-DB, לא נמשכים מה-API בכל בקשה
עמודים סטטיים	Vercel cache
נתוני משתמש	revalidatePath() - רענון ממוקד, לא גורף
ניתוחי יועץ	advisor_insights - ניתוח אחד למשחק משרת את כל מי שפותח אותו
תשובות הספק ליועץ	api_cache ב-DB, תפוגה 12 ש' - שורד גם החלפת פונקציית serverless
העצה היומית (יועץ AI)	מחושבת בלילה, הדאשבורד ודף הנחיתה קוראים טבלה, לא מודל

Pagination

קיים - בכל רשימה שיכולה לגדול.

```
Select ... from bets where user_id = $1  
order by placed_at desc limit 20 offset $2;
```

רשימה	גודל עמוד
היסטוריית ניחושים	20
טבלת דירוג	20
משחקים	20
התראות	20

מגבלה ידועה: OFFSET

OFFSET דורש מה-DB לדלג על N שורות פיזית. בעמוד 500 זה מתחיל להיות יקר.

למה זה מקובל כאן: אף רשימה במוצר לא צפויה להגיע לעומקים כאלה - ליגה של 200 חברים היא 10 עמודים. מה נעשה אם כן: מעבר ל-keyset pagination (where placed_at < \$cursor), שעלותו קבועה ולא תלויה בעומק.

מגבלה אמיתית - מכסת API-Football

בפרויקט זה אנו משתמשים ב-API בו אנחנו משתמשים למוצר אותו שיווקנו בפועל ועליו פירטנו בחלקים קודמים במסמך. במוצר המקורי, השתמשנו בחבילה של 75,000 קריאות ליום כאשר בממוצע נעשה שימוש בכ-15,000 קריאות במוצר שמנה מעל 2,000 משתמשים. כרגע אנחנו לא רואים את הוספת פרויקט זה לסך קריאות ה-API שלו, אך יבוצע מעקב על היקף הקריאות ובמידה ויידרש תבוצע הגדלה של החבילה.

מגבלה נוספת – LLM API tokens

השימוש במודל שפה יכול להשתנות, המנעד גדול והמחיר הסופי תלוי בכמות ובאיכות. בשביל לקבל תוצאות יותר מהימנות ואיכותיות, נדרש שימוש במודל מסחרי מוכר, אך במידה ורוצים להוזיל עלויות ניתן להשתמש במודל חינמי. מניתוח פעולות בסיסיות ביועץ, קיבלנו את הנתונים הבאים:

פעולה	טוקנים	עלות
ניתוח ראשון למשחק	כ-2,100	0.0013\$
שאלת המשך	כ-2,700	0.0012\$
חסימה במסווג	כ-540	0.00006\$
חסימה בשכבה 1	0	0\$

בפרויקט שלנו העדפנו את האמינות ואיכות התשובה על פני המחיר, ולכן בחרנו להשתמש בשלב זה במודל מסחרי מוכר – Gemini 3.5 Flash.

סנכרון חי של משחקים

סנכרון שרץ כל דקה נשמע "יקר", אך הוא לא – ראשית הוא רץ רק בזמנים שיש משחקים פעילים, ויתרה מכך הוא גם קורא באותה הבקשה לכל המשחקים המשוחקים באותו הזמן, וגם מעדכן את בסיס הנתונים בזמן אמת, כך שאין חשיבות לכמות המשתמשים המחוברים.

הפרדה בין צד לקוח לצד שרת

רץ בשרת	רץ בלקוח
שליפת נתונים	אינטראקציה בטפסים
כל הלוגיקה העסקית	ולידציה ויזואלית
כל הולידציות המחייבות	מצב UI מקומי
כל בדיקות ההרשאות	החלפת ערכת נושא
מפתחות API	תזמון הרענון בזמן משחק חי

מגבלות המוצר הנוכחי

#	מגבלה	ההשלכה	ביטוי בפרויקט
1	העיבוד רץ סדרתית - מספר משחקים מסתיימים במקביל	ה-cron מתארך	ניחושים רבים ממתינים
2	תלות בספק חיצוני יחיד	אין נתונים אם הוא נופל	בעת תקלה ב-API הנתונים לא יעודכנו
3	Supabase free tier	MB500, מגבלת חיבורים	משתמשים רבים במקביל ימצו את המכסה
4	Vercel free tier	timeout של 10 שניות ל-function	עיבוד ניחוש המוני
5	יחסים זמניים למשחקים רחוקים	היחס המוצג עשוי להשתנות עד הפתיחה	הובהר בממשק; הניקוד לפי נקודת הניחוש
6	pg_cron מדייק עד דקה	שער מופיע תוך כ-60 ש"י ולא כ-15 ש"י	מקובל - זו תצוגה, לא ניקוד
7	עלות יקרה של מודל שפה	מספר קריאות מוגבל ליום	מכסה יומית למשתמש + cache משותף

שיפורים לגרסה עתידית

טווח קצר - עד כ-10,000 משתמשים

שיפור	מה פותר
Supabase pro + connection pooling	מגבלה 3
Redis לקאשינג של טבלאות דירוג	עומס קריאות לשרתים
Realtime Supabase או SSE לטבלה חיה	מבטל את ה-polling של 30 השניות
תור עבודה לעיבוד במקום cron	מגבלה 1

מה פותר	שיפור
מגבלה 2	מקור נתונים גיבוי
שיפור איכות התשובות	הגדלת השימוש במודל שפה ומעבר למודל טוב יותר (3.7)
טבלה שגדלה בלי מחיקת רשומות שפג תוקפן	ניקוי api_cache מתוזמן
עומס קריאות לשרתים	CDN לתמונות

טווח ארוך - מעל 10,000 משתמשים

מה פותר	שיפור
טבלה שגדלה ללא הגבלה	פיצול (partitioning) של predictions לפי תאריך
הפרדת קריאה מכתובה	Read replicas
שמירה על טבלאות חמות קטנות	מחיקת עונות ישנות

מסמך אבטחה בסיסית

הקדמה

כיום אנו בעיצומה של מהפכת AI שבאה לידי ביטוי בהנגשת בניית הקוד לקהל רחב הרבה יותר בעולם. כתוצאה מכך, המידע של כל משתמש נגיש הרבה יותר, מה שדורש אבטחה הרבה יותר גבוהה מבעבר. במסמך זה נפרט את השיטות בהן אנחנו שומרים על אבטחת המידע באתר שלנו.

מודל האיום

#	גורם "מאיים"	מטרה	חומרה
1	עובד סקרן	לראות ניחושים של עמיתים לפני נעילה	בינוני
2	עובד תחרותי	לשנות לעצמו נקודות, לשנות ניחוש בדיעבד, או לנחש אחרי הפתיחה	גבוה
3	עובד שנוגע ב-DevTools	לעקוף ולידציות של הדפדפן	גבוה
4	גורם חיצוני	גישה לנתוני הארגון	גבוה
5	סורק אוטומטי	ניצול חולשות גנריות	בינוני
6	מתפעל מודל שפה	Prompt injection - לגרום ליועץ לחרוג מתפקידו או לחשוף את הוראותיו	בינוני
7	משתמש שמנסה לשנות הרשאות	לסמן את עצמו כמנהל אתר	גבוה

Authentication - איך מתבצע האימות

המנגנון

Supabase Auth עם אימייל וסיסמה.

פעולות	שלב
Supabase מגבב את הסיסמה ב-bcrypt ושומר ב-auth.users	הרשמה
mailer_autoconfirm פעיל - החשבון פעיל מיד, בלי קישור אימות	
טריגר on_auth_user_created יוצר פרופיל (0 נקודות - אין מענק)	
אימות מול JWT	התחברות
ה-JWT ב-sameSite · secure · httpOnly cookie	שמירת session
middleware.ts מרענן את ה-token בכל בקשה	רענון
ביטול ה-session ומחיקת ה-cookie	התנתקות

Authorization - איך מתבצעות ההרשאות

ארבע דרגות למשתמש

רמה	מי	למה יכול להגיע
אורח	לא מחובר	דף נחיתה, הרשמה, התחברות
משתמש רשום	עובד	הליגות שלו, ניחוש, אתגר, יועץ, פרופיל
אדמין ליגה	leagues.creator_id	לנהל רק את הליגה שיצר
מנהל אתר	profiles.is_site_admin	admin/ - כל משתמש, משחק וליגה; עיבוד, מינוי ומחיקה

שתי שכבות אכיפה - הגנה לעומק

```
request
|
+-- Layer 1: middleware.ts      -> signed in? admin? else redirect
+-- Layer 2: Server Action      -> validation + ownership check
```

```
|
v
+-- Layer 3: RLS in Postgres -> the real line of defence
```

למה שלוש שכבות: שכבות 1–2 הן חוויית משתמש והגנה ראשונה. שכבה 3 היא הביטחון האמיתי - גם אם ייכתב באג באפליקציה שמדלג על בדיקה, ה-DB עדיין לא יחזיר את השורות.

RLS - הליבה

```
alter table predictions      enable row level security;
alter table profiles         enable row level security;
alter table leagues          enable row level security;
alter table league_members   enable row level security;
alter table notifications    enable row level security;
alter table puzzle_attempts  enable row level security;
alter table user_achievements enable row level security;
alter table advisor_insights enable row level security;
alter table advisor_daily_pick enable row level security;
alter table advisor_conversations enable row level security;
alter table advisor_messages enable row level security;
alter table advisor_usage    enable row level security;
alter table api_cache        enable row level security;
```

ניחוסים - קריאה ויצירה של הבעלים בלבד, ללא שינוי או מחיקה:

```
create policy "predictions_select_own" on predictions
  for select using (auth.uid() = user_id);

create policy "predictions_insert_own" on predictions
  for insert with check (auth.uid() = user_id);

-- No UPDATE and no DELETE policy:
-- a user cannot modify or remove a prediction directly.
-- Settlement runs as service role; cancellation goes through
-- a SECURITY DEFINER function.
```

ניסיונות באתגר - קריאה ויצירה של הבעלים; הניקוד נקבע בשרת:

```
create policy "attempts_select_own" on puzzle_attempts
  for select using (auth.uid() = user_id);
```

ליגות - רק ליגות שהמשתמש חבר בהן:

```
create policy "leagues_select_member" on leagues
  for select using (
    exists (select 1 from league_members
            where league_id = leagues.id and user_id = auth.uid())
  );

create policy "leagues_update_creator" on leagues
  for update using (auth.uid() = creator_id);
```

חברי ליגה - רואים רק חברים בליגות משותפות:

```
create policy "members_select_shared_league" on league_members
  for select using (
    exists (select 1 from league_members m
            where m.league_id = league_members.league_id
              and m.user_id = auth.uid())
  );
```

פרופילים - הפרופיל שלך, ופרופילים בליגות משותפות:

```
create policy "profiles_select_visible" on profiles
```

```

for select using (
  auth.uid() = id
  or exists (
    select 1 from league_members a
    join league_members b on a.league_id = b.league_id
    where a.user_id = auth.uid() and b.user_id = profiles.id
  )
);

create policy "profiles_update_own" on profiles
for update using (auth.uid() = id);

```

דף הנחיתה - החלון היחיד שנפתח לאורח

דף הנחיתה מציג שלושה משחקים אמיתיים עם הסיכויים וכרטיס יועץ, אך questions, games ו-advisor_daily_pick פתוחות ל-authenticated בלבד. אותה תבנית: המדיניות נשארת, ונפתחות שתי פונקציות צרות - landing_fixtures() ו-landing_advisor_card() - בלי פרמטרים בכלל, עם המכסה בתוך הגוף (שלוש שורות ואחת), בלי אף מזהה, וב-grant גם ל-anon. מה שנחשף לאורח - שמות קבוצות, מועד, תוצאה ומחירים - פומבי ממילא בכל אתר ספורט.

מניעת שינוי ניקוד והרשאות - נקודה קריטית

ל-profiles יש policy ל-UPDATE (לעריכת שם ואווטאר), ולכאורה משתמש יכול לשנות גם את total_points שלו - ומאז הוספת דרגת מנהל האתר, גם את is_site_admin. המניעה בטריגר:

```

create function prevent_score_tampering() returns trigger
language plpgsql as $$
begin
  if current_setting('role', true) = 'service_role' then return new; end if;

  if new.total_points is distinct from old.total_points
  or new.total_predictions is distinct from old.total_predictions
  or new.total_correct is distinct from old.total_correct then
    raise exception 'score columns cannot be modified directly';
  end if;

  if new.is_site_admin is distinct from old.is_site_admin
  and coalesce(current_setting('app.grant_site_admin', true), 'off') <> 'on' then
    raise exception 'site admin cannot be granted directly';
  end if;

  return new;
end; $$;

create trigger profiles_protect_score
before update on profiles for each row
execute function prevent_score_tampering();

```

המשתמש יכול לעדכן שם ואווטאר בלבד. עמודות הניקוד מתעדכנות אך ורק בעיבוד, ודגל המנהל זו רק דרך admin_set_site_admin() - שפותחת את הטריגר לטרנוקציה שלה בלבד, בודקת שהקורא מנהל, ואוסרת עליו לשנות את עצמו. כך תמיד נותר מנהל אחד לפחות, ומנהל אחד שנפרץ אינו יכול להדיח בשקט את כל השאר.

פעולות המותרות רק למשתמש מחובר

פעולה	אורח	משתמש מחובר	אדמין ליגה	מנהל אתר
צפייה בדף נחיתה	רשאי	רשאי	רשאי	רשאי
הרשמה / התחברות	רשאי	-	-	רשאי
צפייה במשחקים, כולל תוצאות חיות	לא רשאי	רשאי	רשאי	רשאי
הנחת ניחוש (כולל תוצאה מדויקת)	לא רשאי	רשאי	רשאי	רשאי
ביטול ניחוש (עד 10 דק')	לא רשאי	רשאי (רק שלו)	רשאי (רק שלו)	רשאי
יצירה / הצטרפות לליגה	לא רשאי	רשאי	רשאי	רשאי

פעולה	אורח	משתמש מחובר	אדמין ליגה	מנהל אתר
צפייה בטבלת דירוג, כולל התוספת החיה	לא רשאי	רשאי (בליגות שלו)	רשאי	רשאי
אתגר יומי	לא רשאי	רשאי	רשאי	רשאי
שאלת היועץ	לא רשאי	רשאי (10 ליום)	רשאי	רשאי
בחירת משחקים לליגה	לא רשאי	לא רשאי	רשאי (בליגות שלו)	רשאי
סימון בחירת עורך	לא רשאי	לא רשאי	רשאי (בליגות שלו)	רשאי
עדכון פרסי הליגה	לא רשאי	לא רשאי	רשאי (בליגות שלו)	רשאי
עיבוד ידני בליגה	לא רשאי	לא רשאי	רשאי (בליגות שלו)	רשאי
גישה ל-admin - כל משתמש, משחק וליגה	לא רשאי	לא רשאי	לא רשאי	רשאי
מינוי מנהל אתר · מחיקת משתמש	לא רשאי	לא רשאי	לא רשאי	רשאי (לא על עצמו)
הרצת cron	לא רשאי	לא רשאי	לא רשאי	רשאי

מניעת גישה למידע של משתמש אחר

מנגנון 1 - RLS מסנן בשאלתה עצמה

הבקשה נשלחת עם ה-JWT של המשתמש. Postgres מוסיף את תנאי ה-policy לכל שאלתה.

```
select * from predictions // Run by User A
select * from predictions where auth.uid() = user_id // Run by PG
// Result: Only User A results
```

אין דרך לעקוף. גם `select * from predictions` ידני יחזיר רק את השורות המותרות. זו הגנה בשכבת הנתונים, לא באפליקציה.

מנגנון 2 - הנתונים לא עוזבים את השרת

Server Components מרנדרים בשרת ושולחים HTML. אין endpoint שמחזיר JSON גולמי, ואין payload שאפשר לפתוח ב-DevTools ולמצוא בו נתוני משתמש אחר. גם הטבלה החיה: השורות של `league_live_predictions` נקראות ומסוכמות בשרת, ומה שמגיע לדפדפן הוא הסך פר-חבר בלבד.

מנגנון 3 - בדיקת בעלות ב-Actions

כל Action שנוגעת במשאב מאמתת בעלות לפני הפעולה - גם אם RLS ממילא היה חוסם. זה מייצר הודעת שגיאה ברורה במקום תוצאה ריקה מבלבלת.

מקרה מיוחד: ניחושים לפני נעילה

עובד סקרן (איום #1) לא אמור לראות ניחושים של עמיתים לפני שהמשחק ננעל. במוצר הנוכחי אין בכלל מסך שמציג ניחושים של אחרים - הפיצ'ר לא קיים באופן מכוון. `predictions_select_own` מבטיח שגם ניסיון ישיר לא יחזיר דבר.

ולידציה של קלטים

שלוש שכבות

שכבה	מה נבדק	ניתן לעקיפה?	תפקיד
HTML	<code>min, type, required</code>	כן	UX
Zod בשרת	טיפוס, טווח, פורמט	לא	ההגנה
אילוץ DB	<code>FK, UNIQUE, CHECK</code>	לא	רשת אחרונה

בשרת - לא בלקוח

```
export async function makePrediction(input: unknown) {
  const parsed = makePredictionSchema.safeParse(input);
  if (!parsed.success) return { ok: false, error: 'קלט לא תקין' };
}
```

```
// ...  
}
```

הקלט מוגדר **unknown** בכוונה - שום דבר לא נחשב מהימן עד שעבר **parse**.

SQL Injection

לא רלוונטי בארכיטקטורה הזו. ה-Supabase client בונה שאילתות פרמטריות; אין שרשור מחרוזות לתוך SQL. הפונקציות מקבלות פרמטרים מוקלדים.

XSS

React מסמן (escapes) כל טקסט אוטומטית. `<script>alert(1)</script>` בשם תצוגה יוצג כטקסט ולא יורץ. `dangerouslySetInnerHTML` אינו בשימוש בשום מקום בפרויקט - זה כלל מפורש.

CSRF

Server Actions מוגנות מובנית: Next.js מאמת origin ומשתמש ב-tokens חד-פעמיים. ה-cookies מוגדרים `.sameSite`.

הגנה על קריאות ל-API

Server Actions

מימוש	הגנה
הקוד לא נשלח ללקוח	רצות בשרת בלבד
כל Action מאמתת בתחילתה	אימות session
Zod על כל קלט	ולידציה
לפני כל פעולה על משאב	בדיקת בעלות
מובנה ב-Next.js	CSRF

Route Handlers של cron

```
export async function POST(req: Request) {  
  const auth = req.headers.get('authorization');  
  if (auth !== `Bearer ${process.env.CRON_SECRET}`) {  
    return new Response('Unauthorized', { status: 401 });  
  }  
}
```

היועץ - הגנה בשלוש שכבות

מודל שפה מוסיף מחלקת איום מיוחד למוצר: הקלט הוא טקסט חופשי שמגיע למודל. האיומים הגדולים של מצב זה:

שכבה	היכן	עלות	מה נעצר
כללים	lib/advisor/guard.ts	0	ריק · ארוך מדי · תווי בקרה · URL · תבניות injection בעברית ובאנגלית
מסווג	lib/advisor/classifier.ts	כ-0.00006\$	נושא אחר · נושאי כדורגל שאינם קשורים למשחק הנוכחי · מניפולציה
סכמה	lib/advisor/schema.ts	0	פלט שלא עומד בסכמה · המלצה על אפשרות שאינה קיימת במשחק

משתנה	סיווג	חשוף ללקוח?
NEXT_PUBLIC_SUPABASE_URL	ציבורי	כן
NEXT_PUBLIC_SUPABASE_ANON_KEY	ציבורי - כפוף ל-RLS	כן
SUPABASE_SERVICE_ROLE_KEY	סוד - עוקף RLS וטריגרים	לא
FOOTBALL_API_KEY	סוד	לא
CRON_SECRET	סוד	לא
GEMINI_API_KEY	סוד	לא - נקרא רק ב-Server Actions וב-cron
GEMINI_MODEL GEMINI_GUARD_MODEL	תצורה	לא
ADVISOR_DAILY_LIMIT	תצורה - נאכף בשרת, ב-Postgres	לא
LIVE_SCORES_ENABLED	תצורה - מפסק לסנכרון החי	לא

כללי השמירה על הסיווג בפרויקט שלנו

1. `.env*` ב-`gitignore`. מהקומיט הראשון
2. סודות מוגדרים ב-`Vercel Environment Variables` בלבד
3. רק משתנים ציבוריים באמת מקבלים תחילית `NEXT_PUBLIC_`
4. `SUPABASE_SERVICE_ROLE_KEY` מיובא אך ורק ב-`lib/supabase/admin.ts`, שנקרא רק מ-Route Handlers של cron - לעולם לא מ-Server Component או Action של משתמש
5. `.env.example`. בריפו עם שמות בלבד, בלי ערכים.

סיכונים שעדיין קיימים

#	סיכון	חומרה	למה נותר	מה היינו עושים
1	אין אימות אימייל ו-FA2	בינוני	מגבלת הגרסה החינמית של Supabase	מעבר לגרסה בתשלום + שירות אימות (Resend)
2	סיסמה 8 תווים בלי דרישת מורכבות	נמוך	איוון מול UX. מינימום 8 נאכף גם ב-Supabase	שימוש בשירות עזר
3	אין הצפנה ברמת השדה	נמוך	אין מידע רגיש במיוחד	pgcrypto לפי צורך
4	אין מחיקת חשבון בידי המשתמש	בינוני	החלטה מכוונת - למנוע "איפוס" נתונים; מנהל אתר יכול למחוק	מחיקה עצמית + ייצוא נתונים
5	אין הסתרה מהלידרבורד הכללי	בינוני	החלטה מכוונת - הלוח מיועד לכלול את כולם	דגל <code>is_public</code> בפרופיל, או הסתרה ברמת הארגון
6	Prompt injection יצירתי שאינו נתפס בדפוסים	בינוני	שכבה 1 מבוססת דפוסים, ושכבה 11 היא מודל שיכול לטעות	הרחבת הדפוסים + דגימת שיחות שנחשמו
7	אין rate limiting מעבר למכסת היועץ	נמוך	המכסה חוסמת את הנזק הכספי; לא את הרעש	Redis Upstash על ה-Actions